SIEM Implementation In A Corporate Environment

Jonathon S. Lutes

SIEM Implementation

A. Problem Summary 2

B. Stakeholders 4

C. Historical Data 7

D. Project Requirements 9

E. Training 12

F. Required Resources 15

G. Deliverables 17

H. Evaluation approach 21

I. References 25

A. Problem Summary

FinTek is a mid-sized financial technology company, and because of its size and the vertical it operates in, it is a target for various threat actors, ranging from unskilled individuals to nation-state-funded groups. FinTek is headquartered in a single office building with roughly 475 employees, including a 6-person Security Operations Center (SOC) team and a broader 40-person IT department. They rely on various network and security tools, many endpoints, and a cloud infrastructure that are disconnected from one another. These factors, along with an upcoming PCI DSS audit, have prompted FinTek to evaluate options to improve its security systems and log collection.

The current network topology has a perimeter that includes a redundant pair of Palo Alto next-generation firewalls, with dual ISP uplinks serving as the only path in from the internet and out to the Azure-hosted portal via a site-to-site VPN. There are 6 devices in the DMZ, including a public-facing web portal, a VPN gateway, and a mail relay. This is the only segment directly connected to the open internet. The Corporate LAN has around 400 workstations and laptops, 150 VoIP phones, and 25 wireless access points. There is also a Data Center segment that includes 35 servers, including 2 domain controllers, DNS/DHCP, file/print, a backup server, internal line-of-business apps, and database servers. The final network segment is the Payment Processing/Cardholder Data Environment (CDE), which includes 12 devices, the card-processing application, and database servers, isolated from the rest of the network by an internal segmentation firewall.

FinTek currently uses 8 separate tools that generate logs that must be reviewed individually. Those tools (and their associated logs and reports) include, Palo Alto NGFW (firewall logs), CrowdStrike Falcon (Endpoint Detection and Response (EDR) alerts across workstations and servers), Windows Server/Active Directory (authentication and directory logs), Proofpoint (email security gateway logs), Qualys (periodic security scan reports), Imperva (Web

Application Firewall (WAF) logs), Veeam (backup job logs), and Azure Monitor (Cloud-side logs). Given the variety of tools used, analyzing daily logs is burdensome for SOC analysts. In addition, when a security incident occurs, SOC Analysts need to gather logs from all these sources, which slows the investigation and can cause incidents to spread further across the network or become more deeply ingrained in systems. If FinTek were to experience a security breach resulting in data loss, that could cost the company millions in damages. The average cost of a data breach is now roughly $5 million (IBM, 2026), driven by operational downtime, regulatory fines, and reputational damage. This type of data breach is much easier to prevent when data can be reliably collected and correlated.

Three root causes underlie FinTek's log management problem. First, FinTek lacks a centralized platform for log aggregation and correlation. Each of the organization’s eight security tools operates independently of the others, storing its logs within its own console. Because no platform collates this data, SOC analysts must manually log in to each tool during an investigation, which delays detection and slows incident response, as described.

Second, FinTek has never adopted a standardized logging schema across its toolset. The tools currently in use by FinTek were acquired independently over time without a consistent logging standard, so each tool generates logs in its own format. This makes daily log review time-consuming for analysts. When correlating a single event across tools, it is necessary to manually reconcile differing field names, timestamp formats, and severity scales rather than comparing normalized data.

Lastly, FinTek has no automated correlation or alerting capability. Each tool can only alert on activity within its own silo; there is no mechanism to flag patterns that span multiple systems. This failure allows multi-stage attacks and lateral movement to progress undetected. It explains why FinTek cannot produce a tamper-evident, single source of truth as audit evidence for its upcoming PCI DSS audit.

It is essential, when evaluating the implementation of a new system, to conduct a cost-benefit analysis to ensure the technology makes sense to implement. An essential function of implementing a SIEM is reducing the time required to gather and correlate logs. The average annual pay for a SOC analyst at FinTek is $102,000, which translates to roughly $49/hour. According to Splunk, SOC analysts spend an average of 3 hours each day on alert investigations (Regalado, 2024). With 6 analysts, that amounts to 4,680 hours/year, or around $230,000/year, of analyst time tied up in investigations complicated by disconnected sources.

Splunk is a major SIEM tool and will be the tool of choice within the organization, as it has widespread adoption, making it easier to educate employees and hire knowledgeable employees when needed. Based on the current average log ingestion of 12 GB per day, the estimated cost for Splunk is $43,800 per year in licensing and $15,000 for the initial implementation (Bandurchin, 2025). Even when comparing the first year’s cost of around $58,800, there is still a substantial savings opportunity by utilizing a Splunk SIEM solution.

B. Stakeholders

Chief Information Security Officer (CISO)

CISO involvement is critical for this project, as they own FinTek's overall security strategy and approve the SIEM implementation. A major need for the CISO is assurance that the project's implementation will reduce the organization's risk, satisfy audit obligations, and do all this within the allotted budget. The CISO is ultimately accountable if a breach occurs due to delayed detection, which carries reputational and regulatory consequences. The CISO also has significant influence over the project, as they will set project priorities, approve the budget, and define what success means for the SIEM implementation.

Chief Financial Officer (CFO)

The CFO is the budget and business authority for the project; as such, they have the final sign-off on whether the project gets funded. The CFO approves and funds the project, and they need a clear cost-benefit case to justify the investment to leadership. They are accountable for the financial and reputational fallout from a breach and for demonstrating due diligence to the board and regulators. The CFO has significant influence over the project through funding approval, which can halt or accelerate the project timeline.

SOC Operations Manager

The SOC operations manager oversees the SOC's day-to-day operations, manages the team through the SIEM transition, and implements the new monitoring workflow. They need the SIEM to fit into existing shift structures and staffing. The SOC operations manager bears the direct operational burden of disconnected tools through team overtime, missed alerts, and slowed investigations. They also have a strong influence on the project's success, as they define the requirements for dashboards and alerting workflows and validate whether the solution reduces analyst workload.

SOC Analysts

The SOC analysts will be the end users of the SIEM and need an intuitive interface, reliable correlation rules, and reduced manual log collection for the project to succeed. They will be most directly affected by the SIEM implementation, as they currently spend hours per day manually pulling logs from the 8 tools. The SOC analysts have a moderate influence on the project as their front-line feedback shapes the use-case tuning and alert thresholds during testing.

Lead Security Architect

The lead security architect will be responsible for designing the technical integration of the SIEM into FinTek's existing network segments and will need accurate infrastructure documentation and cooperation on change control. The current impact for the lead security architect is a lack of a unified view of the environment needed to design effective detections or to validate that segmentation is working as intended. The solution will provide a fuller view of the environment, enabling simpler and more effective network monitoring. They have significant influence on the project, as they make the technical design decisions and directly determine whether the SIEM meets its detection goals.

Data Privacy Officer (DPO)

The DPO ensures the SIEM design and log retention practices comply with PCI DSS and data privacy obligations. They require visibility into what data is collected and how long it is retained. Currently, reliable, tamper-evident audit evidence cannot be produced, putting the upcoming PCI DSS audit at risk. The DPO has significant influence over the project, as they can block the go-live if compliance requirements are not met.

IT Operations/Network Team

The IT operations and network team are responsible for configuring log forwarding from endpoints, servers, and switches during SIEM onboarding. They need a clear list of log sources and a rollout schedule that avoids disrupting production systems. This team is currently burdened by maintaining 8 disconnected tools without shared visibility, adding operational overhead when troubleshooting cross-system issues. They have a moderate influence on the project implementation, as execution of onboarding depends on their cooperation and bandwidth.

PCI DSS Qualified Security Assessor

The PCI DSS Qualified Security Assessor (QSA) is not involved in the SIEM implementation. However, they need to review evidence that logging and monitoring controls meet the PCI DSS requirements during the upcoming audit. The problem affects them, as FinTek currently cannot verify log integrity or completeness within the organization's fragmented setup, posing a risk of audit findings or failures. The PCI DSS QSA has a moderate-to-high influence on the project's success through the audit. The audit outcome is an external validation point that the project is explicitly trying to satisfy.

C. Historical Data

Vulnerability Scan History

FinTek runs quarterly scans, and the last four have shown an average of 11.5 critical, 48 high, and 122.75 medium vulnerabilities. The average days to remediate a critical vulnerability is 39.5, and a high vulnerability is 69.5 days, which puts the overall average for vulnerability remediation for critical and high-level vulnerabilities at 54.5 days. The Q3 vulnerability scan also revealed 12 critical vulnerabilities, 6 of which were on servers within the Payment Processing/CDE segment. PCI DSS v4.0.1 requirement 6.3.3 requires that patches/updates for critical vulnerabilities be installed within 30 days of release (PCI SSC, 2024, Requirement 6.3.3). An average days-to-remediate of 39.5 days, compared with the PCI DSS requirement of 30 days, puts the organization out of compliance with the framework and at risk of fines and other penalties. This increased remediation timeframe is largely due to the tools being disconnected and lacking an automated way to correlate vulnerabilities that show as open with suspicious activity on those systems.

SOC Operational Metrics

The SOC has been tracking metrics that help better understand the current environment. The SOC team is currently receiving 340 alerts per day, with approximately 85% (289 alerts) requiring manual triage. Once the SOC analysts have gathered those logs, it takes an average of 2.5 minutes to decide whether to flag the alert for further investigation or dismiss it. Approximately 31% of alerts per day are flagged for further investigation, which then takes an average of 12 minutes to investigate fully. Within the 12-minute full investigation time, 7 minutes are spent manually gathering and correlating logs across various tools, and the remaining time is spent on analysis. Alert flagging and investigation currently have each of the 6 members of the SOC team occupied with alert investigation for an average of 5 hours per day.

The heavy time investment in triage and investigation has downstream consequences for detection and response speed. Driven largely by the manual correlation work described, the SOC currently reports a mean time to detect (MTTD) of 9.5 hours and a mean time to respond (MTTR) of 17 hours. Under this workload, approximately 22% of daily alerts are closed without a full investigation due to backlog pressure. The team currently logs around 48 hours of overtime collectively each month to keep pace with the high alert volume.

Prior Audit Results

A pre-assessment was performed 10 months ago by an internal compliance analyst, who flagged 4 main findings mapped to PCI DSS v4.0.1 Requirement 10 (PCI SSC, 2024). Finding 1, labeled high risk, is that FinTek has no centralized log review process; log review is performed ad hoc and only during active investigations, not on a scheduled basis as expected under Requirement 10.4. The prior SOC operational metrics reflect the view that logs are not regularly reviewed and are only reviewed when an alert is flagged for further investigation. Finding 2, labeled medium risk, states that log retention periods are inconsistent across the 8 tools, ranging from 30 days to 13 months, with no retention policy, creating a risk of gaps in the

12-month history PCI DSS typically expects to be readily available. Finding 3, labeled high risk, states that there is no file integrity monitoring or centralized mechanism to detect tampering with audit logs, meaning log integrity cannot be independently verified and indicates a direct compliance gap under Requirement 10.5. Finding 4, labeled medium, is that there is no automated alerting that exists for anomalous access to CDE systems, and that current detection relies on manual review.

D. Project Requirements

Methodology

The design and development of the proposed solution is guided by the NIST Cybersecurity Framework (CSF) 2.0 Detect (DE) function. Within NIST CSF's DE function, the proposed solution follows both the Continuous Monitoring (DE.CM) and Adverse Event Analysis (DE.AE) categories.

Continuous monitoring is addressed through four main subcategories. DE.CM-01 requires that "networks and network services are monitored to find potentially adverse events," which is accomplished by ingesting Palo Alto NGFW logs and monitoring network traffic across the Corporate LAN, DMZ, and CDE segments. DE.CM-03 extends this to personnel activity and technology use, requiring that "personnel activity and technology usage are monitored to find potentially adverse events"; this is achieved by ingesting CrowdStrike Falcon EDR telemetry and Active Directory authentication logs to track endpoint and user activity. DE.CM-06 requires that "external service provider activities and services are monitored to find potentially adverse events," which the solution addresses by ingesting Azure Monitor logs and Proofpoint email gateway logs, since both represent third-party and cloud services outside FinTek's infrastructure. Finally, DE.CM-09 requires that "computing hardware and software, runtime

environments, and their data are monitored to find potentially adverse events," which is met by directly monitoring the Payment Processing/CDE and database servers.

Adverse event analysis is accomplished through four subcategories that build on the visibility provided through DE.CM. DE.AE-02 requires “potentially adverse events are analyzed to understand associated activities better.” The solution fulfills this through correlation rules that add context to alerts rather than forwarding them unexamined. DE.AE-03, which states that “information is correlated from multiple sources,” is a central capability of the proposed solution and directly addresses FinTek’s current inability to correlate data across its eight disconnected tools. DE.AE-04 extends this through requiring that “the estimated impact and scope of adverse events are understood,” which the design satisfies through dashboards that show which systems and network segments are affected by a given alert rather than presenting it in isolation. Finally, DE.AE-07 requires that “cyber threat intelligence and other contextual information are integrated into the analysis,” which is fulfilled by mapping correlation rules to the MITRE ATT&CK framework, ensuring that detections are grounded in known adversary tactics and techniques rather than built ad hoc.

Rollout, Launch, and Implementation Strategy

The implementation plan follows a hybrid project management methodology, consisting of a phased, waterfall-style structure that governs the overall rollout. At the same time, use case and correlation rule development proceeds iteratively, allowing rules to be created, tested against simulated attack traffic, and tuned before full validation. The rollout consists of six phases. Phase 1, Planning and Scoping, defines log source priorities and compliance mappings. Phase 2, Architecture and Deployment, stands up the SIEM platform and supporting infrastructure in a lab environment. Phase 3, Log Source Onboarding, connects the firewall, EDR, identity, email, vulnerability, WAF, backup, and cloud data sources. Phase 4, Use Case and Alert Development, builds correlation rules and dashboards mapped to the MITRE ATT&CK

framework. Phase 5, Testing and Tuning, validates detections against simulated attack scenarios and reduces false positives. Phase 6, Documentation and Reporting, produces the architecture documentation, SOC runbooks, and compliance reporting templates.

Implementation is considered complete when all six phases have concluded and the following criteria are met: all eight priority log sources are successfully being ingested and data is being normalized, at least ten correlation rules have been developed and validated with MITRE ATT&CK techniques, summative testing has been completed and measured against the acceptance criteria and key performance indicators defined in a later section, and all final deliverables have been produced and reviewed by the Lead Security Architect and Compliance & Data Privacy Officer.

Implementation Risks

Several risks could affect the successful implementation of the SIEM, each varying in likelihood and potential impact on the project.

Log source integration delays present a medium-likelihood, medium-impact risk. Since the eight existing tools were acquired independently and use inconsistent APIs and export formats, onboarding may take longer than planned, extending Phase 3 and pushing back the overall project timeline.

A high false-positive rate during initial rule tuning is a high-likelihood, medium-impact risk. New correlation rules can generate excessive alerts before they are fully tuned to the corporate network, undermining SOC confidence in the platform and requiring additional tuning cycles during Phase 5 before the rules are fully reliable.

Limited SOC analyst availability is a medium-likelihood, high-impact risk. Because the SOC team is already occupied with alert investigation for an average of 5 hours per day, the same analysts who need to support testing and validation may have limited bandwidth, risking delays in those phases.

Budget overrun is a medium-likelihood, medium-to-high-impact risk. If actual log ingestion volume exceeds the estimated 12 GB/day used to size the project, licensing costs could rise beyond the projected $58,800 first-year total, requiring the Executive Sponsor to approve additional funding mid-project.

Misconfiguration during onboarding of the Payment Processing/CDE segment is a low-likelihood, high-impact risk. Although unlikely given the segment's existing isolation by an internal segmentation firewall, any misconfiguration in this area could disrupt the card-processing application or introduce new compliance exposure, given its direct relevance to the upcoming PCI DSS audit.

Insufficient analyst adoption following training is a medium-likelihood, medium-impact risk. If analysts continue relying on familiar manual processes out of habit rather than adopting the new platform, the anticipated reduction in investigation time described in the cost-benefit analysis will not fully materialize.

Of these, limited SOC analyst availability poses the greatest risk to the project's timeline, since the same team responsible for daily alert investigation must also support testing and validation. Misconfiguration within the CDE carries the most severe potential impact, given its direct relevance to PCI DSS compliance and the availability of the card-processing application.

E. Training

The training strategy will be divided into the skills required for each position, with materials commensurate with each role. Four roles will be affected by the SIEM implementation and will therefore receive training.

Lead Security Architect

The current Lead Security Architect holds an active Splunk Core Certified User certification. To further elevate their skills and allow them to use the new system, they will need

to receive the Splunk Core Certified Power User certification. As this will be a necessary skill for their position, FinTek will pay for the certification and provide the training they need to obtain it. The training will occur during business hours, both in the time set aside for it and in any additional time they can dedicate to training. There are an estimated 22 hours of training material available on Splunk's website in the track to obtain this certification (Splunk, *Course catalog*). The Lead Security Architect will be allotted 4 hours per day to complete their training, and they should complete the training material within 6 days (including additional time as needed). When they have completed their training, they will be given paid time during the workday to complete their one-hour exam (with extra time before and after for travel or setup).

The content available through Splunk's free training will include: Basic Splunk knowledge (using fields, working with time-based data, statistical processing, and knowledge objects) and more advanced knowledge (comparing values, result modification, correlation analysis, creating knowledge objects, creating field extractions, and data models).

When a new security architect needs to be onboarded in the future and does not have the Splunk Core Certified Power User certification, the training and certification listed above will be provided during onboarding.

SOC Operations Manager and SOC Analysts

To ensure SOC members (both the SOC analysts and the SOC operations manager) have the necessary skills to perform their new job duties, they will need to obtain the Splunk Core Certified User certification. As this will be a necessary skill for their position, FinTek will pay for the certification and provide the training they need to obtain it. The training will occur during business hours, both in the time set aside for it and in any additional time they can dedicate to training. There are an estimated 13 hours of training material available on Splunk's website in the track to obtain this certification (Splunk, *Course catalog*). The members of the SOC team will be scheduled in alternating 4-hour blocks per day to complete their training, and they should

have the training material completed in 3 days, with an additional day if needed. When they have completed their training, they will be given paid time during the workday to complete their one-hour exam (with extra time before and after for travel or setup).

The content available through Splunk's free training will include: Basic Splunk knowledge (using fields, working with time-based data, statistical processing, and knowledge objects) and more advanced knowledge (scheduling reports & alerts, visualizations, leveraging lookups & subsearches, and search optimization).

When a new SOC Operations Manager or SOC Analyst needs to be onboarded in the future and does not have the Splunk Core Certified User certification, the training and certification listed above will be provided during onboarding.

IT Staff

Training for the IT Operations and Network Staff will be delivered through a one-hour instructor-led session. The meeting will take place during scheduled work hours as part of Phase 3. IT staff do not require a vendor certification, since their role involves configuring log forwarding on existing systems rather than utilizing the SIEM platform itself. The session will cover the log-forwarding requirements for each of the eight systems being onboarded and explain why centralized logging is being implemented, providing the necessary context for IT staff.

Following this meeting, IT staff will receive configuration guides for each forwarding method used across FinTek's environment, including syslog-based sources, agent-based sources, and API-based integrations. Each guide will provide the fixed, step-by-step configuration process for its respective systems. The configuration guide will allow IT staff to reference the appropriate instructions as part of the complete onboarding tasks throughout Phase 3, rather than relying solely on what was covered in the initial session.

General Employees

Training for FinTek employees who are not directly affected by the SIEM implementation will consist of a company-wide email sent before the go-live. The email will serve an awareness function, informing employees that a centralized security monitoring platform is being implemented and briefly explaining what it means for them. The communication will address that network activity, authentication events, and endpoint behavior across company systems are now being monitored more closely than before. The correspondence will go over expected maintenance windows and the timeframe for the full implementation. The communication will also reinforce existing security expectations and is limited to transparency rather than competency.

F. Required Resources

Phase 1: Planning and Scoping

This phase relies on existing personnel all contributing time already allocated to their roles. No new technology or licensing costs are required during this phase.

Phase 2: Architecture and Deployment

The Splunk Cloud Platform is required for this phase of the project. Splunk Cloud was selected over an on-premise solution to reduce infrastructure and maintenance costs and shift hosting responsibilities to Splunk. Based on FinTek's average log ingestion of 12 GB per day and the Splunk pay-as-you-go rate of $10 per GB, licensing is projected at approximately $43,800 per year, with an initial implementation cost estimated at $15,000 (Bandurchin, 2025). This phase also relies on the Lead Security Architect and the IT Operations/Network team, using existing staff resources.

Phase 3: Log Source Onboarding

This phase requires the IT Operations/Network team and the Lead Security Architect to configure the eight log sources in accordance with the configuration guides. No additional licensing costs are incurred beyond the Phase 2 platform investment.

Phase 4: Use Case and Alert Development

During this phase, team members must complete vendor training as outlined in the training section of this project. Educational resources are available at no charge through Splunk Education's digital course offerings (Splunk, *Course catalog*). The associated examination fees total $130 per test attempt (*Splunk Core Certified user*). This comprises a single Splunk Core Certified Power User assessment for the Lead Security Architect ($130), along with seven Splunk Core Certified User assessments covering the SOC Operations Manager and six SOC Analysts ($910), bringing total certification expenses to $1,040 and an additional $130 if any additional attempts are needed. Employees will complete this instruction during normal operational hours.

Phase 5: Testing and Tuning

Phase 5 relies on the Lead Security Architect and SOC Analysts, using existing work hours to validate detections against simulated attack scenarios. No additional direct costs are identified for this phase.

Phase 6: Documentation and Reporting

The final phase requires review and sign-off from the Lead Security Architect and Compliance & Data Privacy Officer, using existing staff time to finalize the project's deliverables.

Splunk Cloud licensing and implementation account for approximately $58,800 in Year 1, dropping to approximately $43,800 per year in subsequent years. Certification exam fees add approximately $1,040, bringing the total identified first-year direct cost to approximately

$59,840. This remains well below the approximately $230,000 per year currently lost to manual investigation time, preserving a substantial first-year savings.

G.Deliverables

The project will include 9 distinct deliverables that, upon completion, will indicate the project has been completed. Those deliverables are the Splunk cloud instance, a network and data flow diagram, a use case library, a SOC dashboard, configuration guides, an incident response guidebook, a PCI DSS compliance reporting template, a test summary report, and the final project report.

Splunk Cloud

The project's biggest deliverable is a fully configured Splunk Cloud instance with normalized log ingestion from all eight priority sources: Palo Alto NGFW, CrowdStrike Falcon, Windows Server/Active Directory, Proofpoint, Qualys, Imperva, Veeam, and Azure Monitor. This deliverable directly resolves Root Cause 1, the absence of a centralized log aggregation and correlation platform, and establishes the technical foundation on which every other deliverable in this section depends.

Network and Data-Flow Diagram

A documented network and data-flow architecture diagram will illustrate how log data moves from each of FinTek's network segments, the DMZ, Corporate LAN, Data Center, and Payment Processing/CDE, into the centralized SIEM. The diagram will identify which forwarding method (syslog, agent, or API) is used for each segment's systems and highlight the internal segmentation firewall that isolates the CDE from the rest of the environment. This artifact provides the Lead Security Architect, the IT Operations team, and future auditors with a single

reference point for understanding the SIEM's integration into FinTek's existing infrastructure, supporting both onboarding and the upcoming PCI DSS audit.

Use-Case Library

The use-case library will consist of at least ten correlation rules mapped to the MITRE ATT&CK framework, directly fulfilling NIST CSF DE.AE-07, which calls for integrating threat intelligence and contextual information into event analysis. Each rule will be documented with an associated ATT&CK technique, the log sources it draws from, and its intended detection outcome, ensuring rules are traceable and maintainable.

Role-Based SOC Dashboard

Role-based SOC dashboards provide real-time visibility into network activity, infrastructure health, and endpoint behavior, with access and content tailored to each user's role. SOC Analysts will receive dashboards focused on active alerts and investigation workflows. In contrast, the Lead Security Architect and SOC Operations Manager will receive broader views suited to rule tuning, performance monitoring, and reporting. This tiered access approach reflects the SANS Log Management Policy's access control practice. It also directly supports reducing the MTTD and the MTTR metrics.

Configuration Guides

Configuration guides will provide IT staff with fixed, step-by-step instructions for forwarding logs to the new SIEM, organized by forwarding method: syslog-based sources, agent-based sources, and API-based integrations. These guides will provide staff with a reusable reference as they complete onboarding tasks throughout Phase 3, rather than relying solely on what will be covered in the initial training meeting.

Incident Response Runbook

The incident response runbook gives SOC analysts a structured, branching reference for triaging and escalating alerts generated by the new correlation rules. Unlike the fixed, linear configuration guides, the runbook will account for the decision-making required during an active investigation, outlining escalation paths based on alert severity, affected segment, and whether CDE systems are involved. This deliverable will ensure that correlation rules from the use-case library will translate into consistent analyst action rather than becoming just another disconnected alert source.

PCI DSS Compliance Reporting Template

The PCI DSS compliance reporting template maps directly to Requirement 10 and is designed to remediate the four findings identified in FinTek's internal gap assessment: the absence of scheduled log reviews, inconsistent retention periods, the lack of tamper-evident audit evidence, and missing automated alerts for CDE access. The template will consolidate evidence from the centralized SIEM into a format that the Compliance & Data Privacy Officer and external QSA can reference directly during FinTek's upcoming audit, replacing the ad hoc, tool-by-tool evidence gathering the organization previously relied on.

Test Summary Report

The test summary report documents the results of both formative and summative testing, including log source validation, individual correlation rule testing, and full end-to-end simulated attack scenarios. It will record outcomes against the acceptance criteria and key performance indicators, such as reductions in MTTD and MTTR relative to the 9.5-hour and 17-hour baselines. It will identify rules or configurations that require additional tuning. This report will

give the Lead Security Architect and SOC Operations Manager a documented basis for determining whether the project has met its completion criteria.

Project Report

The final project report will consolidate the results of the entire implementation, summarizing the security problem addressed, the design decisions made, the testing outcomes recorded, and the cost savings realized relative to the projected $230,000 in annual analyst time reclaimed. It will also capture lessons learned during implementation, including any deviations from the original project plan. It will serve as the primary artifact for FinTek's stakeholders to review.

Projected Timeline

The rollout consists of six phases. The project will commence on September 28, 2026, with Phase 1: Planning and Scoping. This phase defines log source priorities and compliance mappings. Planning and scoping are estimated to take two weeks until October 11, 2026. The CISO, SOC Ops Manager, Lead Security Architect, and DPO will be assigned to this phase. Phase 2: Architecture and Deployment will commence the day after Phase 1 has been completed, on October 12, 2026. During Phase 2, the SIEM platform and supporting infrastructure will be stood up in a lab environment. Resources assigned to this phase are the Lead Security Architect and the IT Ops/Network Team. This phase is projected to be completed in three weeks, on November 1, 2026. Phase 3: Log Source Onboarding will connect the firewall, EDR, identity, email, vulnerability, WAF, backup, and cloud data sources. Log Source Onboarding will begin on November 2, 2026, and is estimated to be completed in four weeks on November 29, 2026. The IT Ops/Network team and the Lead Security Architect will be assigned to this phase. Phase 4, Use Case and Alert Development, builds correlation rules and dashboards mapped to the MITRE ATT&CK framework. This phase will start on November 30,

2026, take four weeks, and be completed on December 27, 2026. The Lead Security Architect, SOC Ops Manager, and SOC Analysts will be required for this phase. Phase 5, Testing and Tuning, will commence on December 28, 2026. This phase validates detections against simulated attack scenarios and reduces false positives. It is projected that this phase will take three weeks to complete and will be completed on January 17, 2027. This phase will have the Lead Security Architect and SOC Analysts assigned to it. The final phase, Phase 6: Documentation and Reporting, produces the architecture documentation, SOC runbooks, and compliance reporting templates. This phase will start on January 18th, 2027, and take 2 weeks, being completed on January 31, 2027. This phase will require the Lead Security Architect and the DPO.

H. Evaluation approach

Test Plans

The SIEM implementation will be evaluated through both formative and summative testing, each addressing a different stage of the project. Formative testing will occur throughout implementation, beginning when each priority log source is onboarded. As a source is connected, the Lead Security Architect will confirm that data is arriving, parsing correctly, and normalizing before the connection is considered complete. During Phase 4, each correlation rule will be tested individually against sample log data in a sandbox environment as it is built, confirming that the rule operates under the condition it was designed to detect before it is added to the use-case library. These checks will rely on a dedicated lab environment separate from FinTek's production systems, along with Splunk's built-in search and validation features, allowing issues to be caught and corrected early rather than surfacing during full deployment.

Summative testing will take place at the end of Phase 5, before go-live, and will evaluate the SIEM as a complete system rather than as individual components. This includes end-to-end validation of the deployed platform against the use cases defined during Phase 4. An exercise will also be conducted in which simulated attacks are run against the entire environment. Summative testing will measure whether the SIEM's correlation rules, dashboards, and alerting workflows function together as intended under real-world conditions. Results from this exercise will be captured in a full dashboard and alert review, providing the project team with a complete picture of the platform's readiness before deployment to production.

Acceptance Criteria and Key Performance Indicators

The minimum acceptance criteria will ensure that each threshold corresponds to something the project actually measures. All eight priority log sources must be successfully ingesting and normalizing data before go-live. At least ten correlation rules must be developed and validated against MITRE ATT&CK techniques. During summative testing, the SIEM must demonstrate a measurable reduction in MTTD and MTTR relative to FinTek's current baseline. A false positive rate ceiling will also be established during summative testing, ensuring that newly tuned correlation rules do not generate an unmanageable volume of alerts. Together, these indicators give the project clear, quantifiable thresholds for determining whether the SIEM is ready for production use.

Test Cases & Scenarios

Four test scenarios were selected because each maps to a specific root cause or audit finding, rather than representing a generic checklist. The first scenario will simulate a phishing-driven credential compromise followed by lateral movement toward the Payment Processing and CDE segment. This scenario directly tests Root Cause 3, FinTek's current lack of automated correlation across the disconnected tools, since detecting this type of attack

requires connecting authentication activity in Active Directory with network activity at the firewall, something the organization cannot currently do. The second scenario will simulate an unauthorized access attempt against CDE systems. This scenario will test the SIEM's ability to meet PCI DSS Requirement 10 detection expectations and directly address Finding 4 from FinTek's internal audit, which identified a lack of automated alerting for anomalous CDE access. The third scenario will simulate an attempt to tamper with stored log data. This scenario validates the SIEM's log integrity controls and addresses Finding 3, which identified the lack of any mechanism to detect tampering with audit evidence. The fourth scenario will simulate a multi-source incident that requires simultaneous correlation across firewall, EDR, and Active Directory logs. This scenario tests the SIEM's core function and reflects the fundamental problem this project was undertaken to solve: FinTek's inability to correlate related activity across its eight disconnected tools.

Analysis of Results

Results from both formative and summative testing will be evaluated against the previously defined acceptance criteria and key performance indicators. MTTD and MTTR figures generated during testing will be compared against FinTek's baseline of 9.5 hours MTTD and 17 hours MTTR to determine whether the SIEM has produced a measurable improvement in detection and response speed. Similarly, the false positive rate observed during testing will be compared against the established ceiling to determine whether correlation rules are sufficiently tuned. The Lead Security Architect and the SOC Operations Manager will jointly review results. The Lead Security Architect will be responsible for the technical configuration of correlation rules and dashboards. At the same time, the SOC Operations Manager is responsible for confirming that the resulting workflows are usable for the SOC team's daily operations. If a test case fails to meet acceptance criteria, the affected rule or configuration will be returned to

Phase 4 for additional tuning and retested before summative testing is repeated. All results, including any tuning cycles required to achieve acceptance, will be documented in the test summary report, providing stakeholders with a complete record of how the SIEM was validated before go-live.

I. References

Regalado, P. (2024, November 14). *Splunk Enterprise Security 8.0 and Splunk SOAR 6.3 unify and automate TDIR workflows within the market-leading SIEM*. Splunk. https://www.splunk.com/en_us/blog/security/splunk-enterprise-security-8-0-and-splunk-soar-6-3-unify-and-automate-tdir-workflows-within-the-market-leading-siem.html

Cost of a data breach report 2026. IBM. (2026, June 18). https://www.ibm.com/reports/data-breach

PCI Security Standards Council. (2024). Payment Card Industry Data Security Standard: Requirements and testing procedures (Version 4.0.1). https://www.pcisecuritystandards.org/

Course catalog. Splunk. (n.d.). https://www.splunk.com/en_us/training/course-catalog.html?sort=Newest&filters=filterGroup1FreeCourses%2CfilterGroup2SplunkCoreCertifiedPowerUser

Bandurchin, A. (2025, December 23). Splunk Pricing & Costs: Free VS Enterprise. Uptrace. https://uptrace.dev/blog/splunk-pricing

Splunk Core Certified user. Splunk. (n.d.-b). https://www.splunk.com/en_us/training/certification-track/splunk-core-certified-user.html